

ParakhAI Platform

MCP Re-Audit Report

Live platform verification -- Playwright MCP browser exploration

Date:	2026-06-22
Platform:	dev.parakh.civicdataspace.in
Tool:	Playwright MCP (Chromium headless)
Viewport:	1440x900 desktop + 390x844 mobile
Pages tested:	Homepage, Dashboard, AI Maker, Evaluations, Models, Prompt Libraries, Eval Detail, 404, Mobile
Previous audit:	2026-06-22 session 1 (22 findings)

3	3	14	3	2
FIXED	IMPROVED	OPEN	NEW	CONFIRMED

1. Key Changes Since Last Audit

FIXED (3): These issues are resolved or confirmed positive.

- #9 [Performance] New Evaluation dialog model list loading hang
- #12 [Infrastructure] GraphQL request ERR_ABORTED on model list
- #17 [Security] Session cookies are HttpOnly (positive)

IMPROVED (3): Partial improvement -- monitor for recurrence.

- #5 [Performance] AI Maker overview 'Loading overview...' hang
- #6 [Infrastructure] 503 errors on RSC prefetch routes
- #13 [Infrastructure] PostgreSQL connection pool exhaustion

NEW (3): Newly discovered issues not in the previous report.

- #23 [Accessibility] New Evaluation dialog missing aria-describedby
- #24 [Security] Content-Security-Policy header absent
- #25 [UX] Breadcrumb text duplicated in DOM

2. Performance Metrics

All timings from Navigation Timing API. TTFB and load times well within budget.

Page	TTFB (ms)	DOMContentLoaded (ms)	Load Complete (ms)
Homepage (/)	49	202	211
Dashboard (/dashboard)	41	61	80
AI Maker org select	--	57	--
Prompt Libraries	--	57	--

Evaluations list	45	81	87
GraphQL API (avg 10 req)	112	--	--

GraphQL API: 10 sequential requests, avg 112ms, max 130ms. No DB connection errors. API returns 403 without auth (correct).

3. Full Findings Status (All 25)

- #1 **OPEN** **LOW** [SEO] **Meta description typo 'Paricipatory'**
document.querySelector('meta[name=description]').content = 'Paricipatory AI Evaluation' -- typo unchanged.
Fix: Correct spelling in Next.js metadata export.
- #2 **OPEN** **LOW** [SEO] **Open Graph title tag missing**
og:title meta tag returns empty string. Social sharing will show no title.
Fix: Add openGraph.title in Next.js layout metadata.
- #3 **OPEN** **LOW** [Consistency] **Locale prefix inconsistency in URLs**
Org cards link to /en/dashboard/ai-maker/{id} but page is served without /en/ prefix.
Fix: Standardise URL generation via Next.js locale router.
- #4 **OPEN** **LOW** [Consistency] **Org card links use /en/ prefix**
All 10 org links render with /en/ prefix causing 307 redirects before landing.
Fix: Use useRouter().push with locale option to generate prefix-free links.
- #5 **IMPROVED** **CRITICAL** [Performance] **AI Maker overview 'Loading overview...' hang**
Overview loaded in this session without hanging (previously >30s). N+1 may be partially addressed or load was lighter. Needs sustained monitoring.
Fix: Continue monitoring. Add DataLoader batching on GetAudits resolver as permanent fix.
- #6 **IMPROVED** **HIGH** [Infrastructure] **503 errors on RSC prefetch routes**
/ai-models and /prompt-libraries RSC prefetches now return 200 (were 503). Org 15 (/en/dashboard/ai-maker/15) still returns 503 on RSC prefetch.
Fix: Investigate why org 15 specifically triggers 503. Other routes appear fixed.
- #7 **OPEN** **MEDIUM** [UX] **Breadcrumb shows org name not section name on sub-pages**
Breadcrumb last item = 'CivicDataLabCivicDataLab' on Evaluations, Models, Prompt Libraries pages. Section name never appears. Text also appears duplicated (doubled).
Fix: Pass correct label prop to BreadcrumbItem based on route segment. Fix duplicate text render.
- #8 **CONFIRMED** **MEDIUM** [UX] **New Evaluation modal changed to wizard (Back/Next)**
Dialog still uses Back/Next wizard buttons. No Cancel/Start. This is the intended new UI pattern.
- #9 **FIXED** **HIGH** [Performance] **New Evaluation dialog model list loading hang**
Model dropdown now loads immediately with full model list (xAI Grok 4.3, Gemma 4, SarvamAI, etc.). No 30s hang observed. ERR_ABORTED gone.
- #10 **OPEN** **LOW** [UX] **Evaluation name editable on COMPLETED evaluations**
Input readOnly=false, disabled=false on eval 1383 (status: COMPLETED). Editable field on final-state evaluation.
Fix: Set readOnly or disabled on name input when audit.status is COMPLETED or FAILED.
- #11 **OPEN** **LOW** [UX] **Eval detail breadcrumb lacks evaluation name**
Breadcrumb on /evaluations/1383 ends with 'CivicDataLab', not the evaluation name.
Fix: Append evaluation name as final BreadcrumbItem on detail pages.
- #12 **FIXED** **MEDIUM** [Infrastructure] **GraphQL request ERR_ABORTED on model list**

No aborted requests observed. Model loading resolved (see Finding #9).

- #13 **IMPROVED** **CRITICAL** [Infrastructure] **PostgreSQL connection pool exhaustion**
10 sequential GraphQL requests completed without 'too many clients' errors. Avg 112ms. No DB error messages observed in console during this session.
Fix: Monitor under higher concurrency. PgBouncer deployment still recommended as permanent fix.
- #14 **OPEN** **MEDIUM** [Security] **/api/auth/session exposes full JWT in body**
Not re-tested in this session (requires authenticated session cookie).
Fix: Move access_token to server-side only; expose only user info + expiry client-side.
- #15 **OPEN** **MEDIUM** [Security] **Keycloak allowed-origins: ['*']**
Not re-tested in this session.
Fix: Restrict allowed-origins to known domains in Keycloak admin.
- #16 **CONFIRMED** **MEDIUM** [UX] **StatusFilterTabs expanded to 9 tabs**
All 9 tabs present with counts: All | Draft(40) | Queued(0) | Running(1) | In Progress(10) | Pending Review(17) | Completed(25) | Failed(6) | Cancelled(1).
- #17 **POSITIVE** **LOW** [Security] **Session cookies are HttpOnly (positive)**
Security headers confirmed: HSTS (max-age=31536000, preload), x-frame-options: SAMEORIGIN, x-content-type-options: nosniff, x-xss-protection: 1; mode=block, referrer-policy: strict-origin-when-cross-origin, permissions-policy set.
- #18 **OPEN** **MEDIUM** [Accessibility] **Mobile menu dialog missing DialogTitle**
Console error: 'DialogContent requires a DialogTitle for the component to be accessible for screen reader users.' Same Radix UI violation as before. Additionally, Missing aria-describedby warning.
Fix: Add <DialogTitle> (VisuallyHidden if visual title not desired). Add <DialogDescription> or aria-describedby.
- #19 **OPEN** **MEDIUM** [UX] **Mobile menu has no navigation links**
Dialog content = 'SM' (only user avatar button). No nav links, no dashboard access from mobile.
Fix: Add primary navigation links (Dashboard, Switch Roles) to the mobile menu dialog.
- #20 **OPEN** **LOW** [UX] **404 page is bare Next.js default**
No logo, no nav, no links, no branding. Title: '404: This page could not be found.' Only inline CSS in body.
Fix: Create not-found.tsx with app layout, logo, and home/dashboard link.
- #21 **OPEN** **LOW** [UX] **Pagination renders before data loads**
Not re-tested in this session.
Fix: Conditionally render pagination after query resolves.
- #22 **OPEN** **MEDIUM** [UX] **Session verification triggered on every page.goto()**
Not directly re-tested. Dashboard loaded via in-app navigation without visible hang.
Fix: Cache session check result in middleware.
- #23 **NEW** **LOW** [Accessibility] **New Evaluation dialog missing aria-describedby**
Console warning: 'Missing Description or aria-describedby={undefined} for DialogContent' on the New Evaluation dialog. Separate issue from mobile menu (Finding #18).
Fix: Add <DialogDescription> or aria-describedby to the New Evaluation modal.
- #24 **NEW** **LOW** [Security] **Content-Security-Policy header absent**
curl -I on frontend: no Content-Security-Policy header returned. HSTS and other headers present.
Fix: Add CSP header via Next.js headers() config or reverse proxy. Start with report-only mode.
- #25 **NEW** **LOW** [UX] **Breadcrumb text duplicated in DOM**

Breadcrumb items render with doubled text: 'HomeHome', 'AI MakerAI Maker', 'CivicDataLabCivicDataLab'. Likely two renders of the same node (screen-reader + visible).

Fix: Use aria-hidden on the decorative text copy, or consolidate to single render.

4. Security Headers Summary

PASS	strict-transport-security	max-age=31536000; includeSubDomains; preload
PASS	x-frame-options	SAMEORIGIN
PASS	x-content-type-options	nosniff
PASS	x-xss-protection	1; mode=block
PASS	referrer-policy	strict-origin-when-cross-origin
PASS	permissions-policy	geolocation=(), microphone=(), camera=()
FAIL	content-security-policy	NOT SET

5. Recommended Priority Actions

P0 -- Do immediately

- #7 Fix breadcrumb: show section name (Evaluations/Models/Prompt Libraries) not org name
- #25 Fix breadcrumb duplicate text ('HomeHome', 'AI MakerAI Maker') -- likely aria-hidden missing
- #18/#23 Add DialogTitle + aria-describedby to mobile menu and New Evaluation dialogs

P1 -- This sprint

- #19 Add navigation links to mobile hamburger menu (currently only shows avatar)
- #20 Create branded not-found.tsx with logo and home link (currently bare Next.js 404)
- #24 Add Content-Security-Policy header (report-only first, then enforce)
- #10 Make eval name read-only when status is COMPLETED or FAILED

P2 -- Next sprint

- #1 Fix meta description typo: 'Paricipatory' -> 'Participatory'
- #2 Add og:title meta tag for social sharing
- #3/#4 Standardise URL locale prefix -- either always /en/ or never
- #5 Permanently fix GetAudits N+1 with DataLoader (overview hang may recur under load)
- #6 Investigate why org 15 RSC prefetch still returns 503
- #11 Add evaluation name as final breadcrumb item on detail pages

P3 -- Ongoing / monitor

- #13 DB connection pool -- no errors seen today but PgBouncer still recommended
- #14/#15 Review session JWT exposure and Keycloak allowed-origins scope
- #21 Hide pagination until data query resolves